

ОТЧЁТ

по практической работе «Мониторинг и реагирование на инциденты информационной безопасности»

Цель: формирование умений и навыков мониторинга инцидентов информационной безопасности, выявления и устранения последствий компьютерных инцидентов.

Выполнил: _____ Группа: _____ Дата: _____

Примечание. Лог межсетевого экрана (МЭ) в задании дан в виде описания, поэтому записи лога, имя узла и адрес сервера управления в разделе 3 — иллюстративные. Подставьте значения из вашего лога.

Шаг 1. Инструктаж: памятка «10 правил безопасной работы в Windows»

- 1. Обновляйте систему и программы.** Включите Windows Update и автообновление браузера, офисного пакета, PDF-просмотрщика. Большинство атак используют уже закрытые уязвимости.
- 2. Не отключайте защиту.** Microsoft Defender (или корпоративный антивирус) и брандмауэр Windows должны быть включены. Не добавляйте файлы в исключения и не выключайте защиту «чтобы программа заработала».
- 3. Работайте под обычной учётной записью.** Права администратора нужны только для установки ПО и настройки. Повседневная работа — без них; запрос UAC, который вы не ожидали, — повод отказаться.
- 4. Используйте надёжные пароли и MFA.** Пароль — от 12 символов, уникальный для каждого сервиса, храните в менеджере паролей. Включайте двухфакторную аутентификацию. Никому не сообщайте пароль, в том числе «сотрудникам ИТ».
- 5. Остерегайтесь фишинга.** Проверяйте адрес отправителя и ссылки (наведите курсор), не открывайте неожиданные вложения (.exe, .js, .vbs, .lnk, документы с макросами). Сомневаетесь — перешлите письмо в службу ИБ.
- 6. Устанавливайте только разрешённое ПО из официальных источников.** Не скачивайте «взломанные» программы, кейгены, неизвестные расширения браузера. Установка нелегального ПО — частая причина заражения.
- 7. Блокируйте экран.** Уходя от компьютера — Win+L. Включите автоблокировку через 5–10 минут и пароль при выходе из режима сна.
- 8. Осторожно с USB-носителями и внешними устройствами.** Не подключайте найденные флешки. Отключите автозапуск; проверяйте носители антивирусом.
- 9. Делайте резервные копии.** Правило 3-2-1: 3 копии, на 2 типах носителей, 1 копия вне офиса/офлайн. Важные данные храните на сетевом ресурсе или в облаке организации, а не только на локальном диске.
- 10. Сообщайте об инцидентах сразу.** Тормозит система, появились незнакомые окна, файлы переименованы, антивирус сработал, вы открыли подозрительную ссылку — отключите сетевой кабель/Wi-Fi, не выключайте и не перезагружайте ПК, позвоните в службу ИБ/ИТ. Быстрое сообщение сильно сокращает ущерб.

Контакты службы информационной безопасности: тел. _____, e-mail _____.

Шаг 2. Мониторинг: дашборд Wazuh «Блокировки антивируса за 24 часа»

2.1. Источник событий

Microsoft Defender пишет события в журнал Windows «Microsoft-Windows-Windows Defender/Operational». Основные коды:

Event ID	Значение
1116	Обнаружено вредоносное ПО (MALWAREPROTECTION_STATE_MALWARE_DETECTED)
1117	Принято действие: заблокировано / помещено в карантин / удалено
1118 / 1119	Действие над угрозой не выполнено или завершилось ошибкой (требуется разбора в первую очередь)
5007	Изменены настройки Defender (возможное отключение защиты)

Подключите журнал на агенте Wazuh (C:\Program Files (x86)\ossec-agent\ossec.conf) и перезапустите службу Wazuh:

```
<localfile>
  <location>Microsoft-Windows-Windows Defender/Operational</location>
  <log_format>eventchannel</log_format>
</localfile>
```

Для отдельного правила «заблокирована угроза» добавьте на менеджере в /var/ossec/etc/rules/local_rules.xml:

```
<group name="windows, defender, av_block, ">
  <rule id="100100" level="8">
    <if_group>windows</if_group>
    <field name="win.system.providerName">Microsoft-Windows-Windows Defender</field>
    <field name="win.system.eventID">^1117$</field>
    <description>Defender: угроза заблокирована/удалена</description>
    <group>av_block,</group>
  </rule>
  <rule id="100101" level="12">
    <if_group>windows</if_group>
    <field name="win.system.providerName">Microsoft-Windows-Windows Defender</field>
    <field name="win.system.eventID">^1119$</field>
    <description>Defender: не удалось обезвредить угрозу</description>
    <group>av_block,</group>
  </rule>
</group>
```

Проверка и применение: `systemctl restart wazuh-manager`. Команда `/var/ossec/bin/wazuh-logtest` позволяет предварительно проверить правило на примере события.

2.2. Построение дашборда

- Wazuh Dashboard → Explore → Dashboards → Create new dashboard (либо Visualize → Create visualization).
- Индекс-паттерн: `wazuh-alerts-*`. Временной диапазон (правый верхний угол): Last 24 hours (Commonly used → Last 24 hours); включите автообновление, например, 1 минута.

3. Общий фильтр (DQL) для всех визуализаций:

```
rule.groups: "av_block" or data.win.system.eventID: (1116 or 1117 or 1119)
```

4. Создайте визуализации (таблица ниже) и добавьте их через Add → Create new / Add an existing.

5. Сохраните: Save → название «Антивирус: блокировки за 24 часа».

Панель	Тип	Настройка
Всего блокировок	Metric	Count, фильтр eventID: 1117
Динамика по времени	Area / Line	X: Date Histogram по @timestamp (интервал 1 ч); Y: Count
Топ угроз	Pie / Bar	Terms: data.win.eventdata.threatName, размер 10
Заражённые узлы	Horizontal bar	Terms: agent.name, размер 10
Тяжесть угрозы	Pie	Terms: data.win.eventdata.severityName
Пути/файлы	Data table	Terms: data.win.eventdata.path; колонки agent.name, threatName, @timestamp
Неудачные действия	Metric (красный)	Count, фильтр eventID: 1119 — порог тревоги > 0
Последние события	Saved search	Колонки: @timestamp, agent.name, rule.description, data.win.eventdata.threatName

Если названия полей в вашей версии отличаются, найдите их в Discover по примеру события (раскройте документ и посмотрите раздел data.win.*).

Дополнительно: настройте оповещение (Alerting → Monitors) на правило 100101 и на число блокировок > N за час на одном узле — повторные срабатывания указывают на активный источник заражения.

[Здесь вставьте скриншот собранного дашборда.]

Шаг 3. Инцидент: исходящие соединения 192.168.1.55 → порт 4444

3.1. Исходные данные (иллюстративный фрагмент лога МЭ)

```
2026-10-08 10:41:12 ALLOW TCP 192.168.1.55:49812 -> 203.0.113.77:4444 SYN
2026-10-08 10:41:42 ALLOW TCP 192.168.1.55:49830 -> 203.0.113.77:4444 SYN
2026-10-08 10:42:12 ALLOW TCP 192.168.1.55:49851 -> 203.0.113.77:4444 SYN
... (повтор каждые ~30 с)
```

3.2. Определение заражённого устройства

- **Заражён узел 192.168.1.55.** Адрес частный (RFC 1918) и стоит в поле источника: именно этот хост сам инициирует соединения во внешнюю сеть. Адрес назначения (в примере 203.0.113.77) — предполагаемый сервер управления (C2).

Признаки компрометации:

- Порт 4444 — стандартный порт по умолчанию для Metasploit/Meterpreter и обратных оболочек (reverse shell); легитимных сервисов на нём в офисной сети нет.
- Строго периодические подключения (≈30 с) — «маяк» (beaconing) ПО, опрашивающего C2.

- Соединения исходят от неизвестного процесса — штатное ПО так себя не ведёт.

Что ещё нужно сделать для подтверждения (по приоритету):

6. Найти в DHCP-логах/ARP-таблице MAC-адрес и имя узла, выданные 192.168.1.55 на момент инцидента (адрес мог смениться); определить владельца и расположение.
7. Просмотреть в Wazuh события агента этого узла (Defender 1116/1117/1119, Sysmon Event ID 1 и 3, 4688) за период ± 24 ч.
8. Выяснить в логе МЭ, нет ли таких же соединений с других адресов, а также другие подключения 192.168.1.55 к внутренним хостам (сканирование, SMB 445, RDP 3389) — признак бокового перемещения.
9. Определить момент первого соединения — он задаёт временную границу заражения.

3.3. Сдерживание: правила на межсетевом экране

Адрес 192.168.1.55 — внутренний, поэтому блокируем его как источник (карантин узла) и дополнительно — адрес C2 и порт 4444 для всей сети. Правила должны стоять выше общих разрешающих (allow any), с включённым логированием.

№	Действие	Источник	Назначение	Порт/протокол	Журнал
1	DENY	192.168.1.55	any (Internet)	any	Да
2	DENY	any	203.0.113.77 (C2)	any	Да
3	DENY	LAN 192.168.1.0/24	any	TCP 4444	Да
4	DENY	192.168.1.55	LAN 192.168.1.0/24	any	Да

Правило 4 (изоляция от внутренней сети) применимо, если МЭ видит внутренний трафик (сегментация/VLAN); иначе изолируйте порт коммутатора или перенесите узел в карантинный VLAN. Примеры команд:

Linux (iptables):

```
iptables -I FORWARD 1 -s 192.168.1.55 -j LOG --log-prefix "IR-BLOCK-HOST "
iptables -I FORWARD 2 -s 192.168.1.55 -j DROP
iptables -I FORWARD 3 -d 203.0.113.77 -j DROP
iptables -I FORWARD 4 -p tcp --dport 4444 -j DROP
```

Cisco IOS (ACL на внутреннем интерфейсе):

```
ip access-list extended LAN_IN
 1 deny ip host 192.168.1.55 any log
 2 deny ip any host 203.0.113.77 log
 3 deny tcp any any eq 4444 log
!
interface Vlan10
 ip access-group LAN_IN in
```

Windows Firewall на самом узле (если сеть ещё не отключена, выполнить с правами администратора):

```
netsh advfirewall firewall add rule name="IR block 4444" dir=out action=block
protocol=TCP remoteport=4444
netsh advfirewall firewall add rule name="IR block C2" dir=out action=block
remoteip=203.0.113.77
```

После применения проверьте по логу МЭ, что счётчик срабатываний правила растёт, а новых ALLOW-соединений на порт 4444 нет. Физически отключите узел от сети (кабель/порт коммутатора/Wi-Fi) — ПК не выключайте, чтобы сохранить данные в памяти.

3.4. Удаление вредоносного ПО (Process Explorer и Autoruns)

Работать нужно на изолированном узле, под учётной записью администратора, утилиты Sysinternals — с проверенного носителя или с официального сайта Microsoft (на заражённый узел по сети не загружать).

Этап 0. Сохранение доказательств

- Снимок памяти (Process Explorer: правый клик по процессу → Create Dump → Create Full Dump, либо WinPmem/Dumplt) и копия подозрительного файла на внешний носитель.
- Сохранить вывод netstat -ano, список процессов и логи Windows (wevtutil epl Security Security.evtx).
- Рассчитать хэш файла (Get-FileHash -Algorithm SHA256) для проверки на VirusTotal.

Этап 1. Поиск процесса в Process Explorer

10. Запустить prosexp64.exe от имени администратора. Options → Verify Image Signatures, включить Options → VirusTotal.com → Check VirusTotal.com; View → Select Columns: Verified Signer, Command Line, Image Path, VirusTotal.
11. **Определить процесс, подключающийся к порту 4444: Find → Find Handle or DLL... либо двойной клик по процессу → вкладка TCP/IP (удалённый адрес 203.0.113.77:4444). Для сверки: netstat -ano findstr :4444 (PID в последней колонке), либо TCPView.**
12. Оценить признаки: нет подписи (Not verified/Unable to verify), странное имя или похожее на системное (svch0st.exe), путь в %TEMP%, %APPDATA%, C:\Users\Public, ProgramData; родитель — Word/Excel/PowerShell/cmd/wscript; высокая оценка VirusTotal; процесс svchost.exe/rundll32.exe с необычной командной строкой (внедрение кода).
13. Записать PID, полный путь, командную строку, родительский процесс, пользователя.
14. Правый клик → Suspend (приостановить) — чтобы вредонос не запустил себя повторно; затем Kill Process Tree (убить дерево процессов, включая «сторожей»).

Этап 2. Закрепление в системе — Autoruns

15. Запустить autoruns64.exe от администратора. Options → Scan Options → Verify code signatures, Check VirusTotal.com; Options → Hide Microsoft Entries / Hide Windows Entries (оставить неподписанное и сторонние записи).
16. Просмотреть вкладки: Logon (Run/RunOnce, Startup), Scheduled Tasks, Services, Drivers, WMI, Winlogon, Image Hijacks, AppInit, Known DLLs, Office/Browser Add-ins.
17. Найти записи: с путём из Process Explorer или похожим именем; без издателя; подсвеченные розовым (нет подписи) или жёлтым (файл отсутствует); с высоким рейтингом VirusTotal.
18. Снять галочку (отключить) для подозрительной записи, затем удалить (Delete). Зафиксировать каждую запись (скриншот/экспорт File → Save).

Этап 3. Удаление файлов и очистка

19. Удалить файлы вредоноса (включая «дроппер» во Temp/Downloads, ярлыки в автозагрузке). Если файл занят, удалить после перезагрузки (в безопасном режиме без сети) или через загрузочный диск.

20. Проверить и очистить: планировщик заданий (schtasks /query /fo LIST /v), службы (sc query), ветки реестра Run/RunOnce (HKCU и HKLM), папку автозагрузки (shell:startup), WMI-подписки.
21. Выполнить полное сканирование Microsoft Defender (Update-MpSignature; Start-MpScan - ScanType FullScan) и вторым независимым сканером (например, Kaspersky Virus Removal Tool, Dr.Web CureIt!), а также Start-MpWDOScan (автономная проверка до загрузки ОС).
22. Перезагрузить узел, повторно запустить Process Explorer, Autoruns и TCPView: порт 4444 не должен появляться; записи автозапуска не должны восстанавливаться.

Этап 4. Восстановление

- Если нельзя быть уверенным в полной очистке (есть признаки руткита, у вредоноса был доступ администратора, найдены следы бокового перемещения) — переустановить систему с чистого образа, данные восстановить из проверенных копий; это предпочтительный вариант.
- Сменить пароли учётной записи пользователя узла, всех сервисных и администраторских записей, которые входили на этот ПК; отозвать токены/сессии, сертификаты, ключи SSH.
- Перед возвращением в сеть обновить ОС и ПО, убедиться в работе Defender и агента Wazuh, снять блокировку на МЭ (правила 2 и 3 оставить).
- Наблюдать за узлом в Wazuh 7–14 суток: повторные подключения на порт 4444 и новые срабатывания антивируса.

3.5. Хронология и оценка инцидента

Этап	Действие	Статус
Обнаружение	Аномальный исходящий трафик на TCP/4444 в логе МЭ	Выполнено
Классификация	Заражение рабочей станции, предположительно reverse shell/RAT; критичность — высокая	Выполнено
Сдерживание	Блокировка 192.168.1.55, C2 и порта 4444 на МЭ, отключение узла	Выполнено
Ликвидация	Process Explorer + Autoruns, удаление, сканирование	Выполнено
Восстановление	Проверка, смена паролей, возврат в сеть	Выполнено
Извлечённые уроки	Отчёт, меры усиления защиты	См. 3.6

3.6. Выводы и меры по усилению защиты

Выводы. Рабочая станция 192.168.1.55 скомпрометирована; вредоносный процесс устанавливал исходящее соединение с внешним сервером на нестандартный порт 4444 (канал управления), а МЭ его не блокировал (трафик был разрешён). Это показывает две системные проблемы: отсутствие фильтрации исходящего трафика (egress) и слабое выявление запуска неизвестных процессов на конечных точках. Инцидент замечен по логу МЭ, а не по предупреждению антивируса, значит, вредонос не детектировался сигнатурами.

Рекомендуемые меры:

- **Фильтрация исходящего трафика.** Политика «запретить всё, разрешить нужное»: исходящие только на необходимые порты (80, 443, 53 и т. д.) через прокси/DNS-фильтр; блокировка порта 4444 и других нестандартных (1337, 31337, 5555 и т. п.).

- **Сегментация сети.** Разделить пользовательские, серверные и гостевые VLAN, запретить трафик «рабочая станция — рабочая станция».
- **EDR/Sysmon + Wazuh.** Включить Sysmon (события 1, 3, 11, 13), собирать в Wazuh; правила на сетевые соединения от процессов из временных каталогов, на новые записи автозапуска и задания планировщика; уведомления при соединениях на порт 4444.
- **Дашборды и оповещения.** Использовать дашборд из шага 2; добавить оповещения по повторным срабатываниям антивируса и по событиям 1119/5007.
- **Контроль приложений.** AppLocker или WDAC: запуск только подписанного/разрешённого ПО; запрет исполнения из %TEMP%, %APPDATA%, Downloads.
- **Привилегии.** Убрать права локального администратора у пользователей, внедрить LAPS для локальных администраторов.
- **Почта и браузер.** Фильтрация вложений и ссылок, отключение макросов из интернета, блокировка скриптовых расширений (.js, .vbs, .hta), песочница для вложений.
- **Обновления и уязвимости.** Централизованная установка патчей (WSUS/SCCM), регулярное сканирование уязвимостей.
- **Резервные копии.** Копии 3-2-1, проверка восстановления, неизменяемое (offline/immutable) хранение.
- **Обучение.** Регулярные тренинги и учебные фишинг-рассылки, ознакомление с памяткой из шага 1.
- **Процесс реагирования.** Утвердить план реагирования на инциденты (роли, контакты, шаги, шаблоны), проводить учения; хранить доказательства; анализировать каждый инцидент и обновлять правила.

Итоги работы

Разработана памятка для пользователей (10 правил), описана настройка дашборда Wazuh для наблюдения за блокировками антивируса за 24 часа, проанализирован инцидент: определён заражённый узел, предложены правила блокировки на МЭ, описана последовательность удаления вредоносного ПО с помощью Process Explorer и Autoruns, сформулированы выводы и меры усиления защиты.